

API Architecture

Document:

`docs/architecture/API_ARCHITECTURE.md`

System: HackNest — Student Operating System

Status: Authoritative — reconciled against

`README.md` , `MASTER_ARCHITECTURE.md` ,

`DATABASE_ARCHITECTURE.md` ,

`SECURITY_ARCHITECTURE.md` ,

`MASTER_GOVERNANCE_AMENDMENT_001.md`

Type: Architecture Specification Only — No Implementation

Per `MASTER_ARCHITECTURE.md` Section 9, this document is the sole authoritative owner of: request/response contracts, versioning, and rate-limit tier enumeration. It defers audit log record shape, RLS policy design, and RPO/RTO entirely to their true owners.

0. Relationship to Governing Documents

Uses the canonical domain list

(`DATABASE_ARCHITECTURE.md` Section 4) and role set

(MASTER_ARCHITECTURE.md Section 5) without redefinition. Rate-limit values below are sourced directly from MASTER_GOVERNANCE_AMENDMENT_001.md Section 4.1, resolving the "referenced but never enumerated" gap identified in ARCHITECTURE_VALIDATION_REPORT.md .

1. Purpose

HackNest's API layer mediates every interaction between client surfaces and the domains defined in DATABASE_ARCHITECTURE.md , in a way that is safe, predictable, and consistent regardless of domain. The server is the source of truth; every request is validated and authorized before it acts; every response has a predictable shape; the API surface grows by domain, not feature sprawl.

2. API Principles

- **Server-first**, per MASTER_ARCHITECTURE.md Section 2 — all data access and mutation executes server-side.
- **Type-safe**, using Zod-derived types shared between validation and TypeScript.

- **Secure by default** — nothing is public unless explicitly designed to be, per `SECURITY_ARCHITECTURE.md` Section 1.
 - **REST conventions** for Route Handlers (external/public); **Server Actions** for internal, UI-triggered mutations.
 - **Consistent response structure** (Section 5) with no exceptions.
 - **Versioning** — external Route Handlers are versioned in the URL path (`/api/v1/...`), per `CODING_STANDARDS.md` Section 4.
 - **Idempotency** — retryable mutating operations (invite acceptance, submission) use idempotency keys so repeated execution produces the same end state.
-

3. API Domains

Domain responsibilities exactly match

`DATABASE_ARCHITECTURE.md` Section 4

(Authentication, Students, Universities, Profiles, Skills, Teams, Projects, Hackathons, Organizations, Communities, Chat, Messages, Notifications, Search, Feed, Achievements, Bookmarks, Files, Admin, Analytics, Settings). This document does not restate domain data shape — only each domain's API contract surface (endpoints/actions, not entities).

4. Request Standards

- **Validation** via Zod on every request payload before business logic executes.
- **Authentication** verified before any other processing (per `SECURITY_ARCHITECTURE.md` Section 9).
- **Authorization** checked at the API layer independently of RLS (`SECURITY_ARCHITECTURE.md` Section 4/7 Defense in Depth).
- **Input sanitization** per `SECURITY_ARCHITECTURE.md` Section 16.
- **Rate limiting** per Section 6 below.
- **Error handling** normalized to Section 5's error shape, never leaking internals.

5. Response Standards

Success: `{ success: true, data, meta? }`

Error: `{ success: false, error: { code, message, details? } }`

Validation error: a specialization of the error shape with `error.details` as a field-level array, never echoing sensitive values.

Pagination: `{ data: [...], meta: { pagination:`

`{...} }` , using cursor-based pagination by default for large/volatile collections (Messages, Notifications, Search, Feed), per Section 8.

6. Rate Limiting Tiers (Authoritative Values)

Sourced from

`MASTER_GOVERNANCE_AMENDMENT_001.md` Section 4.1:

Category	Limit
Authentication (sign-in/sign-up)	10 req / 5 min per IP; 5 req / 5 min per account
Password reset / email verification	3 req / 15 min per account or email
General authenticated reads	300 req / min per account
Mutating actions	60 req / min per account
Messaging (send)	30 messages / min per account
Search	60 queries / min per account

Category	Limit
Unauthenticated public reads	100 req / min per IP
File upload	20 uploads / hour per account

Limits fail closed (Section 17 of `SECURITY_ARCHITECTURE.md`): if the limiter is unreachable, requests are denied, never silently unlimited.

7. Security

Owned in depth by `SECURITY_ARCHITECTURE.md`; this document's role is ensuring every API surface actually implements: declared authentication requirements, authorization checked post-authentication, CSRF protection for cookie-based Server Actions, XSS-safe output encoding, and secure headers applied uniformly — per `SECURITY_ARCHITECTURE.md` Section 8.

8. Performance

- Cursor-based pagination default for Messages, Notifications, Search, Feed; offset-based permitted only for small, stable, admin-facing collections.
 - Caching applied to read-heavy, low-volatility domains (Universities, Skills, published Hackathon listings), invalidated on the underlying mutation.
 - Response-time targets are owned by `TESTING_STRATEGY.md` (sourced from `MASTER_GOVERNANCE_AMENDMENT_001.md` Section 4.5); this document ensures endpoint design (pagination, filtering, indexing alignment with `DATABASE_ARCHITECTURE.md` Section 12) supports meeting them.
-

9. Monitoring

Request logging, error logging, and audit events per category defined in `SECURITY_ARCHITECTURE.md` Section 19 and `DATABASE_ARCHITECTURE.md` Section 9 – this document does not redefine the audit record shape, only confirms every API mutation that qualifies produces one.

10. Documentation

Every domain's contract is documented with request/response shape, auth/authz requirements, and rate-limit tier (Section 6), generated as close to the Zod schemas as possible to avoid drift. Breaking changes to versioned Route Handlers ship with a migration note.

Definition of Done

- [x] Architecture only — no endpoints, no business logic, no code.
 - [x] Reconciled against `MASTER_ARCHITECTURE.md`, `DATABASE_ARCHITECTURE.md`, `SECURITY_ARCHITECTURE.md`, `MASTER_GOVERNANCE_AMENDMENT_001.md`.
 - [x] Rate-limit tiers now contain actual values (Section 6), closing the previously-flagged gap.
-

Validation Report

Internal consistency: confirmed — Section 6 is the single source of rate-limit values, referenced (not restated) wherever else rate limiting is mentioned.

Cross-document consistency: domain list matches `DATABASE_ARCHITECTURE.md` Section 4 exactly; defers audit log shape, RLS design, and RPO/RTO to their

true owners; rate-limit values match

MASTER_GOVERNANCE_AMENDMENT_001.md Section 4.1

verbatim. **Resolved audit finding:** the "rate limits referenced but never enumerated" gap from

ARCHITECTURE_VALIDATION_REPORT.md is closed.

**Status: Validated — Reconciled — Ready to Govern
Implementation**